



Agentic AI Application

Security Assessment Report

2026-03-25

HIGH RISK

34 findings identified

0

CRITICAL

7

HIGH

17

MEDIUM

10

LOW

Disclaimer

Assessment Notice

This security assessment was generated using tachi, an automated threat modeling toolkit. The analysis applies STRIDE methodology and AI-specific threat categories to the provided architecture description. Results reflect the automated analysis and should be validated by qualified security professionals.

Scope Limitation

This assessment is limited to the architecture description provided at the time of analysis. It does not cover runtime behavior, implementation-level vulnerabilities, or threats arising from future system changes. The assessment scope is defined in the Assessment Scope section of this report.

Recommendation

This automated assessment should complement, not replace, manual security review by qualified professionals. Organizations should conduct periodic penetration testing, code review, and architecture review in addition to automated threat modeling.

Confidentiality

This document contains sensitive security assessment information. Distribution should be limited to authorized personnel with a legitimate need to review the security posture of the assessed system. Do not share externally without appropriate authorization.

Table of Contents

Disclaimer 2

Table of Contents 3

Risk Methodology 4

Assessment Scope 8

Executive Summary 10

Executive Threat Architecture 12

Risk Reduction Funnel 23

Risk Summary Dashboard 24

System Architecture 25

Findings Detail — Residual Risk 27

Control Coverage 33

Remediation Roadmap 34

Risk Methodology

Threat Identification

This assessment uses STRIDE threat modeling combined with AI-specific threat categories to provide comprehensive coverage of both traditional and emerging attack vectors.

STRIDE Categories

Spoofing — Impersonating a user, component, or system to gain unauthorized access.

Tampering — Unauthorized modification of data in transit, at rest, or in processing.

Repudiation — Performing actions without adequate logging or accountability trails.

Information Disclosure — Exposing sensitive data to unauthorized parties through leaks or side channels.

Denial of Service — Degrading or disrupting system availability through resource exhaustion or abuse.

Elevation of Privilege — Gaining higher access rights than authorized through exploitation of trust boundaries.

AI-Specific Categories

Prompt Injection — Manipulating AI model behavior through crafted inputs that override system instructions.

Tool Abuse — Exploiting AI agent tool access to perform unintended or unauthorized operations.

Agent Autonomy — Risks from AI agents acting beyond their intended scope without adequate human oversight.

Data Poisoning — Corrupting training data or context to degrade model accuracy or introduce bias.

Model Theft — Unauthorized extraction or replication of proprietary model weights or behavior.

Probability x Impact Matrix

Each identified threat is assessed for probability of occurrence and potential impact. The intersection determines the overall severity rating used throughout this report.

Impact / Probability	Rare	Unlikely	Possible	Likely	Almost Certain
Critical	H	H	C	C	C
High	M	M	H	C	C
Moderate	L	M	M	H	H
Low	L	L	M	M	H
Negligible	L	L	L	M	M

■ C = Critical
 ■ H = High
 ■ M = Medium
 ■ L = Low

Quantitative Risk Scoring

When quantitative data is available, each threat receives a composite risk score derived from four independent dimensions. This provides a more granular risk ranking than severity alone.

Scoring Dimensions

Dimension	Range	Description
CVSS 3.1 Base Score	0 – 10	Industry-standard vulnerability severity rating based on attack vector, complexity, and impact.
Exploitability	0 – 10	Ease of exploitation considering required skills, tooling availability, and attack complexity.
Scalability	0 – 10	Potential for automated or mass exploitation across multiple targets or instances.
Reachability	0 – 10	Network accessibility of the vulnerable component from the attacker's perspective.

Composite Score Formula

The composite risk score is a weighted average of the four dimensions:

$$\text{Composite} = (\text{CVSS} \times 0.40) + (\text{Exploitability} \times 0.25) + (\text{Scalability} \times 0.20) + (\text{Reachability} \times 0.15)$$

Weights reflect the relative importance of each dimension: CVSS captures inherent severity (40%), exploitability measures practical attack feasibility (25%), scalability accounts for blast radius (20%), and reachability assesses network exposure (15%).

Compensating Control Analysis

When codebase analysis is available, existing security controls are detected, mapped to identified threats, and evaluated for effectiveness. This provides a residual risk assessment that accounts for defenses already in place.

Analysis Process

1. **Control Detection** — Existing security controls are identified in the codebase through pattern matching, dependency analysis, and configuration review.
2. **Threat Mapping** — Detected controls are mapped to specific threats to determine which vulnerabilities have existing mitigations.
3. **Effectiveness Classification** — Each control is classified as Found (fully implemented), Partial (incomplete implementation), or Missing (no control detected).
4. **Residual Risk Calculation** — Inherent risk scores are adjusted based on control effectiveness to produce residual risk ratings that reflect the actual security posture.

Assessment Overview

Assessment Scope

7 Components

13 Data Flows

3 Trust Boundaries

Components Analyzed

Name	Type	Description
User	External Entity	End user who submits prompts and queries to the system via HTTPS
Guardrails Service	Process	Input validation and filtering service that screens user prompts before forwarding to the orchestrator, rejects non-compliant prompts with reasons
LLM Agent Orchestrator	Process	Central agentic AI coordination service that processes validated prompts, retrieves context from the Knowledge Base, dispatches tool calls to the MCP Tool Server, generates responses, and logs decisions
MCP Tool Server	Process	Model Context Protocol tool execution server that receives JSON-RPC tool call requests from the orchestrator, invokes external APIs, and returns results
Knowledge Base	Data Store	Vector search data store used by the orchestrator for context retrieval via semantic similarity search
Audit Logger	Data Store	Centralized logging data store that records decision log entries from the orchestrator, tool execution logs from the MCP Tool Server, and filtering event logs from the Guardrails Service
External API	External Entity	Third-party external API service consumed by the MCP Tool Server over HTTPS

Data Flows

Source	Destination	Data	Protocol
User	Guardrails Service	Prompt / Query	HTTPS
Guardrails Service	LLM Agent Orchestrator	Validated Prompt	Not specified
Guardrails Service	User	Rejected Prompt + Reason	HTTPS
LLM Agent Orchestrator	Knowledge Base	Context Retrieval query	Vector Search
Knowledge Base	LLM Agent Orchestrator	Retrieved Documents	Vector Search
LLM Agent Orchestrator	MCP Tool Server	Tool Call Request	JSON-RPC
MCP Tool Server	LLM Agent Orchestrator	Tool Result	JSON-RPC
MCP Tool Server	External API	API Request	HTTPS
External API	MCP Tool Server	API Response	HTTPS

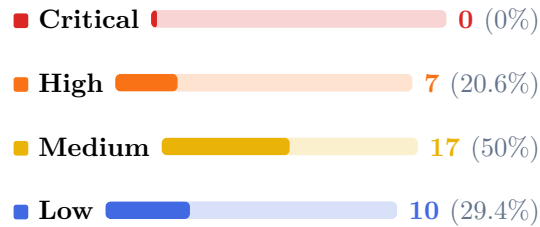
Source	Destination	Data	Protocol
LLM Agent Orchestrator	User	Response	HTTPS
LLM Agent Orchestrator	Audit Logger	Decision Log Entry	Not specified
MCP Tool Server	Audit Logger	Tool Execution Log	Not specified
Guardrails Service	Audit Logger	Filtering Event Log	Not specified

Trust Boundaries

Zone	Trust Level	Components
User Zone	Untrusted	User
Application Zone	Semi-Trusted	Guardrails Service, LLM Agent Orchestrator, MCP Tool Server, Knowledge Base, Audit Logger
External Services	Untrusted	External API

Executive Summary

Severity Distribution 34 findings total



Component Distribution

Component	Findings
LLM Agent Orchestrator	11
MCP Tool Server	8
Guardrails Service	6
Audit Logger	3
Knowledge Base	3
User	2
External API	1

Assessment Summary

The system presents an ****elevated risk posture**** with 8 Critical and 14 High findings requiring immediate attention. The LLM Agent Orchestrator is the highest-risk component, concentrating 11 of 34 findings across all threat categories including AI-specific threats. Positively, the architecture includes a dedicated Guardrails Service for input filtering and an Audit Logger for centralized logging – these components, once hardened, provide strong foundations for defense-in-depth.

- **Direct Prompt Injection (LLM-1, Critical)**:** Adversarial prompts can override the Orchestrator's system instructions, potentially causing harmful content generation, data disclosure, or unauthorized actions. This is the most accessible attack vector requiring no special access.
- **Unauthorized Consequential Actions (AG-1, Critical)**:** The Orchestrator can execute irreversible external operations (API calls, data writes) without human approval, meaning a single misinterpreted instruction could cause permanent data loss or financial damage.
- **Tool Access Without Authorization (E-2, E-3, AG-3, Critical)**:** Neither the Orchestrator nor the MCP Tool Server enforces role-based access control on tool dispatch, allowing standard users to invoke privileged operations including data exports and configuration changes.
- **Service Impersonation (S-3, Critical)**:** The JSON-RPC channel between the Orchestrator and MCP Tool Server lacks mutual authentication, enabling an attacker to forge tool call requests by impersonating the Orchestrator.
- **Entry Point Denial of Service (D-1, D-2, Critical)**:** Both the Guardrails Service and the Orchestrator lack rate limiting and input size caps, enabling an attacker to exhaust compute resources with high-volume or maximum-length requests.
 - **Implement role-based access control (RBAC)**** on all tool dispatch paths in both the Orchestrator and MCP Tool Server before deployment.
 - **Deploy structured prompt templates**** with explicit boundary enforce

Executive Threat Architecture

Executive Threat Architecture

Agentic AI Application — Risk Assessment Summary

User Zone

User

External Services

External
API

Application Zone



High Severity

An attacker can craft a trick prompt that overrides the AI assistant's safety rules and makes it behave in unapproved ways.

LLM-1

Audit
Logger

Guardrails
Service

Knowledge
Base

LLM Agent
Orchestrator

MCP Tool
Server

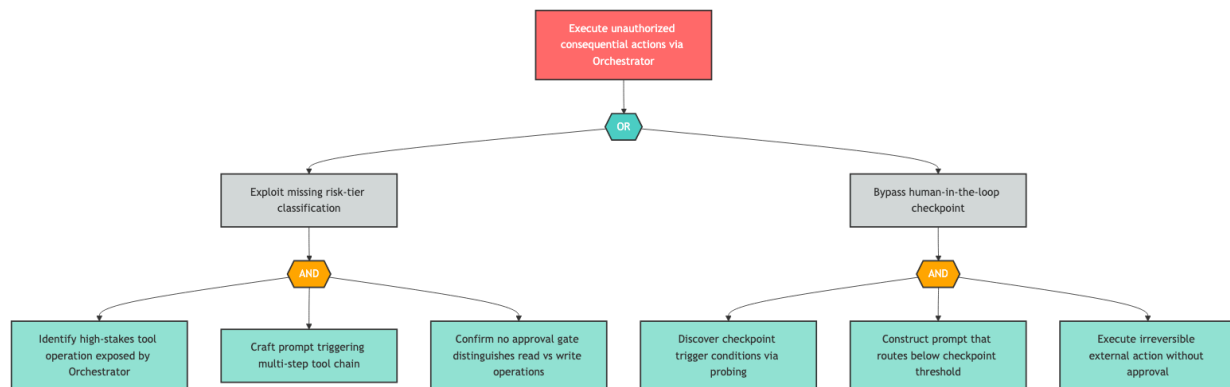
Layered system architecture with critical and high severity threats annotated as narrative callouts. This visualization highlights where the most exposed components sit in the system and what kind of attack each layer is most vulnerable to.

Attack Path Analysis

Attack Path Analysis

HIGH AG-1 — Autonomous Consequential Action Execution

Component: LLM Agent Orchestrator



An attacker targets LLM Agent Orchestrator by attempting to execute unauthorized consequential actions via orchestrator. The attack proceeds through combinations of several attack paths. Required attacker actions include "Identify high-stakes tool operation exposed by Orchestrator", "Craft prompt triggering multi-step tool chain", "Confirm no approval gate distinguishes read vs write operations", and 3 additional actions.

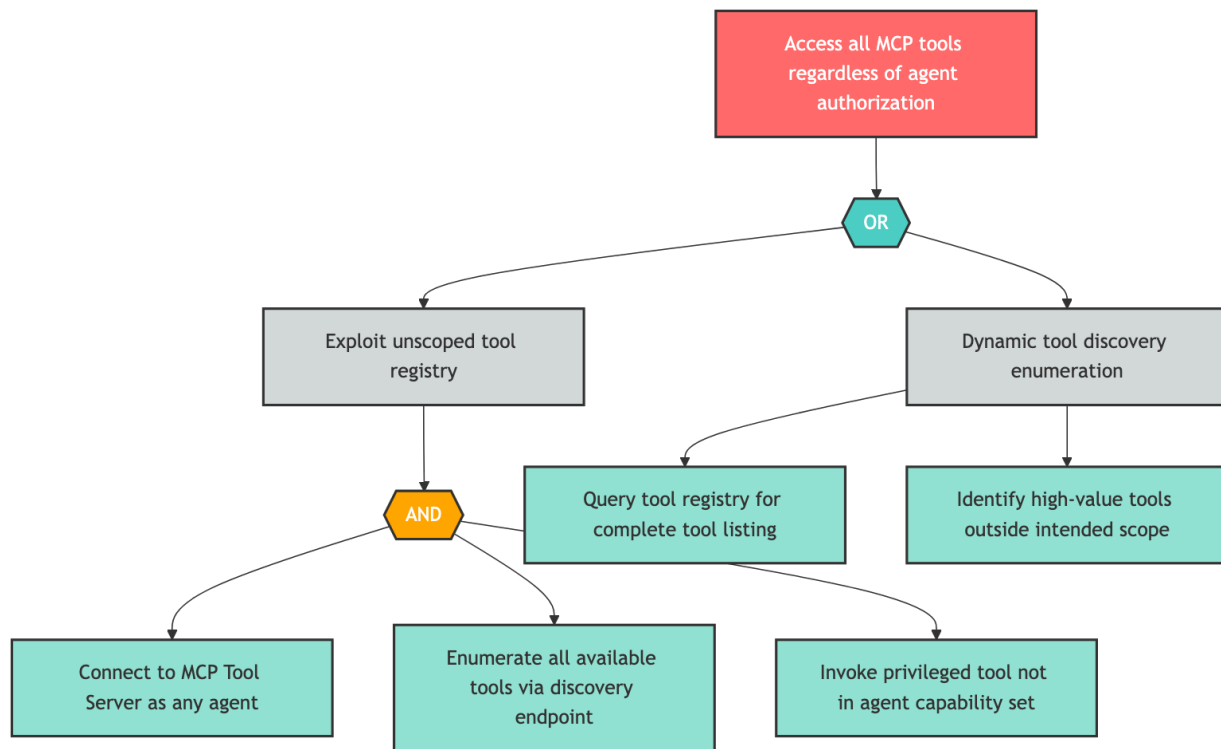
Remediation Steps

- Establish human-in-the-loop checkpoints for all irreversible or external actions.
- Classify operations by risk tier and require explicit user approval for consequential actions.

Attack Path Analysis

HIGH AG-3 – Unscoped Tool Access on MCP Server

Component: MCP Tool Server



An attacker targets MCP Tool Server by attempting to access all mcp tools regardless of agent authorization. The attack proceeds through combinations of several attack paths. Required attacker actions include "Connect to MCP Tool Server as any agent", "Enumerate all available tools via discovery endpoint", "Invoke privileged tool not in agent capability set", and 2 additional actions.

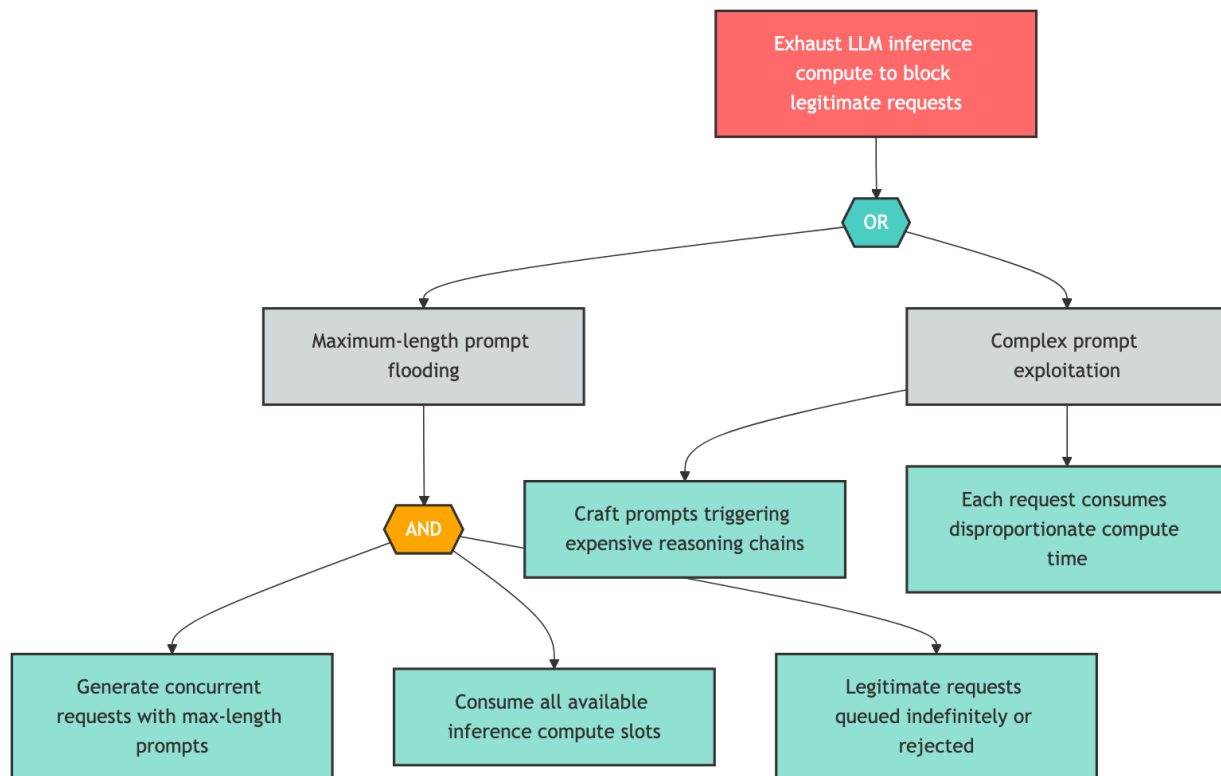
Remediation Steps

- Review and implement appropriate security controls.

Attack Path Analysis

HIGH D-2 — Orchestrator Compute Exhaustion

Component: LLM Agent Orchestrator



An attacker targets LLM Agent Orchestrator by attempting to exhaust llm inference compute to block legitimate requests. The attack proceeds through combinations of several attack paths. Required attacker actions include "Generate concurrent requests with max-length prompts", "Consume all available inference compute slots", "Legitimate requests queued indefinitely or rejected", and 2 additional actions.

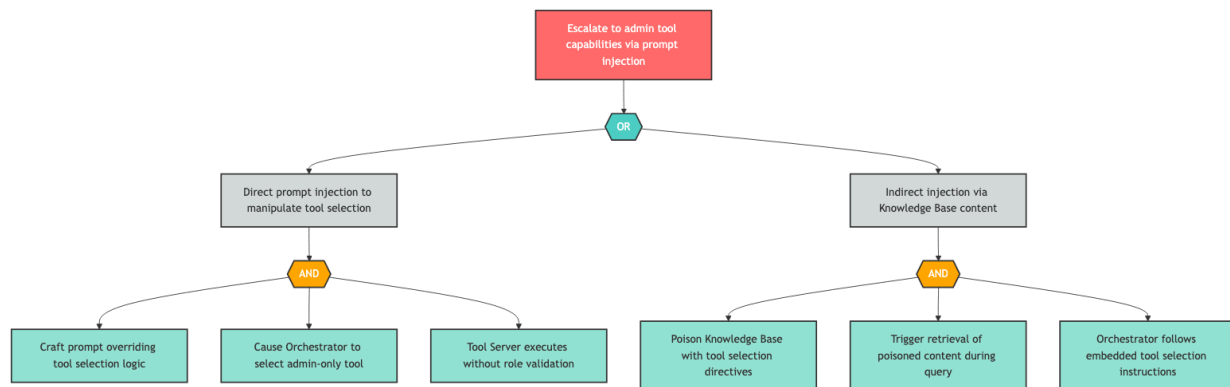
Remediation Steps

- Add input size caps and concurrent request limits at the orchestrator layer.
- Implement request queuing with timeout to prevent resource exhaustion from parallel maximum-length prompts.

Attack Path Analysis

HIGH E-2 — Privilege Escalation via Tool Selection Manipulation

Component: LLM Agent Orchestrator



An attacker targets LLM Agent Orchestrator by attempting to escalate to admin tool capabilities via prompt injection. The attack proceeds through combinations of several attack paths. Required attacker actions include "Craft prompt overriding tool selection logic", "Cause Orchestrator to select admin-only tool", "Tool Server executes without role validation", and 3 additional actions.

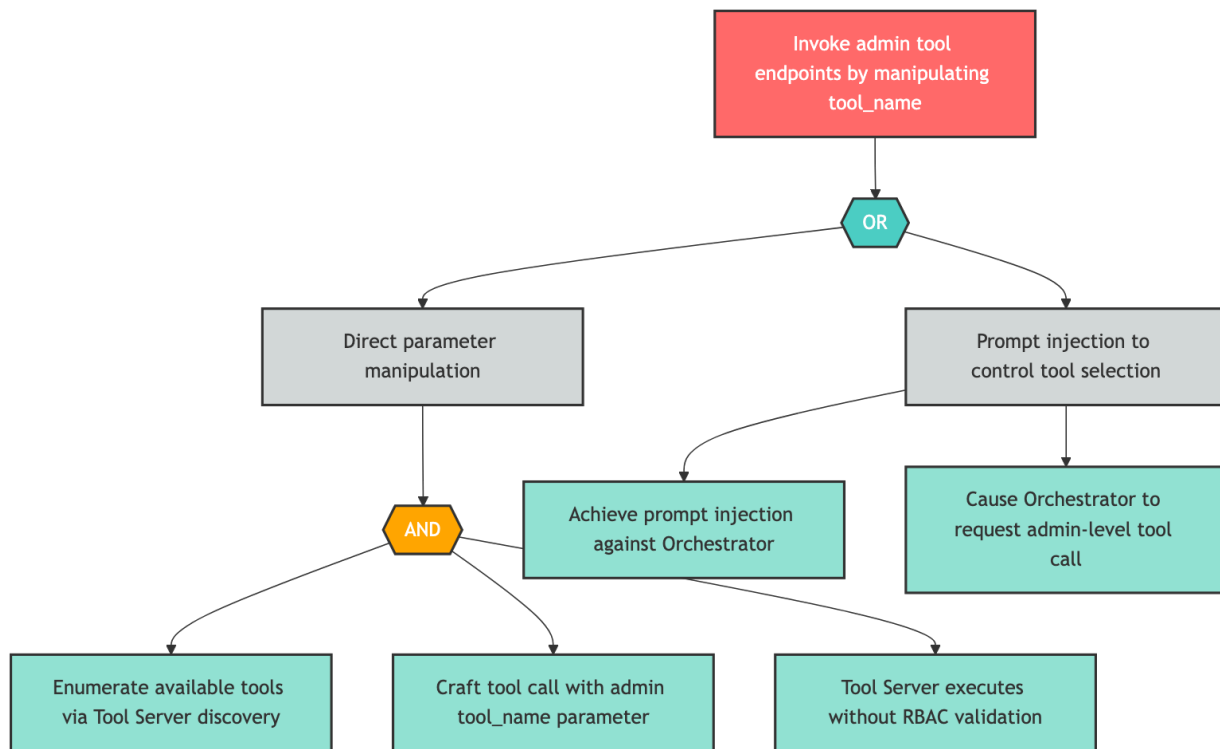
Remediation Steps

- Implement role-based access control on tool dispatch.
- Map user roles to permitted tool sets and enforce at the orchestrator level before dispatching to MCP Tool Server.

Attack Path Analysis

HIGH E-3 — Administrative Tool Access via Parameter Manipulation

Component: MCP Tool Server



An attacker targets MCP Tool Server by attempting to invoke admin tool endpoints by manipulating `tool_name`. The attack proceeds through combinations of several attack paths. Required attacker actions include "Enumerate available tools via Tool Server discovery", "Craft tool call with admin `tool_name` parameter", "Tool Server executes without RBAC validation", and 2 additional actions.

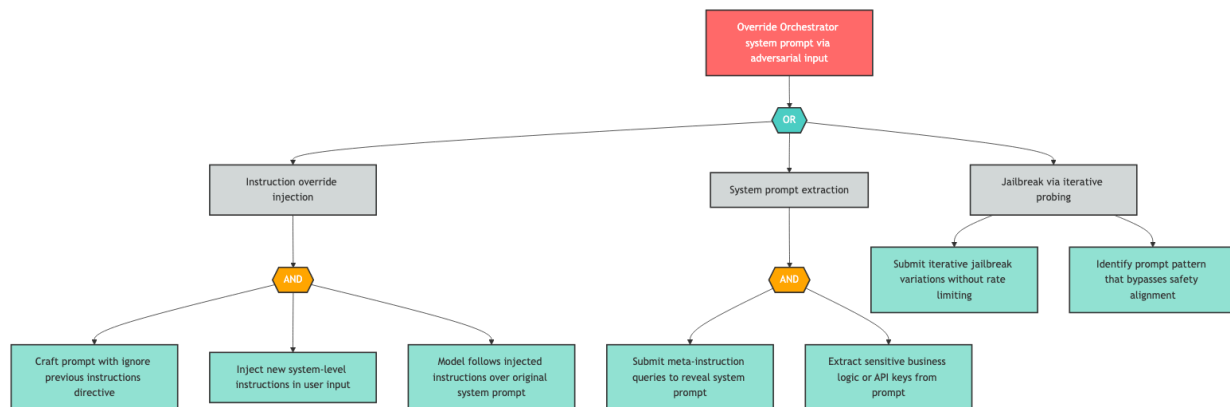
Remediation Steps

- Enforce per-agent capability scoping on the MCP Tool Server.
- Each connected client should only access tools permitted by its role and session context.

Attack Path Analysis

HIGH LLM-1 — Direct Prompt Injection

Component: LLM Agent Orchestrator



An attacker targets LLM Agent Orchestrator by attempting to override orchestrator system prompt via adversarial input. The attack proceeds through combinations of several attack paths. Required attacker actions include "Craft prompt with ignore previous instructions directive", "Inject new system-level instructions in user input", "Model follows injected instructions over original system prompt", and 4 additional actions.

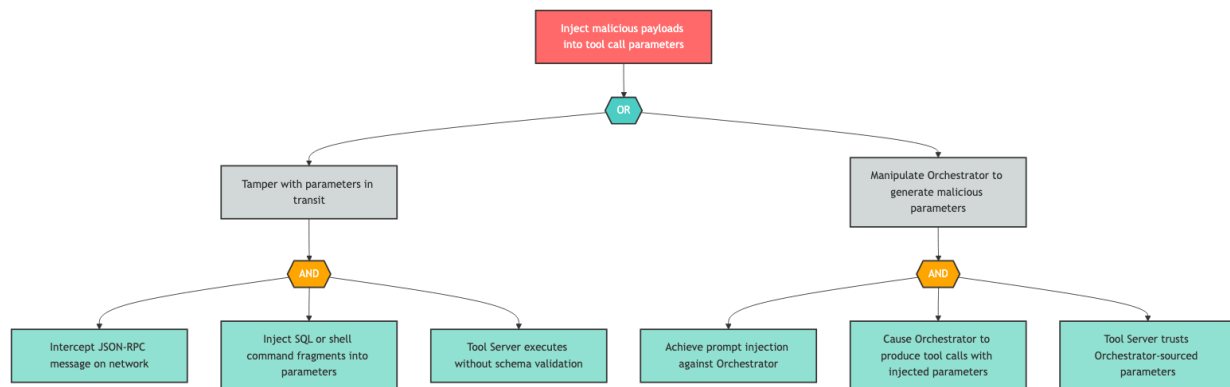
Remediation Steps

- Deploy structured prompt templates with explicit boundary enforcement between system instructions and user input.
- Use delimiters, role markers, and instruction hierarchy to prevent adversarial prompt override.

Attack Path Analysis

HIGH T-3 – JSON-RPC Parameter Injection

Component: MCP Tool Server

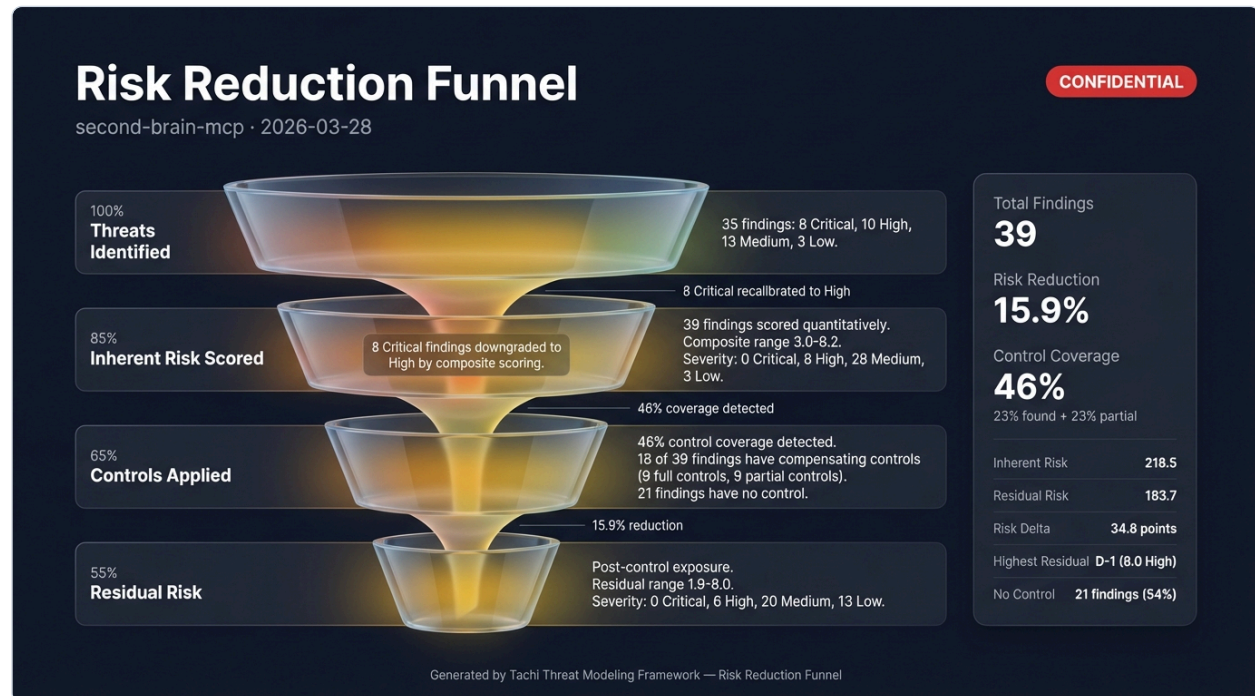


An attacker targets MCP Tool Server by attempting to inject malicious payloads into tool call parameters. The attack proceeds through combinations of several attack paths. Required attacker actions include "Intercept JSON-RPC message on network", "Inject SQL or shell command fragments into parameters", "Tool Server executes without schema validation", and 3 additional actions.

Remediation Steps

- Review and implement appropriate security controls.

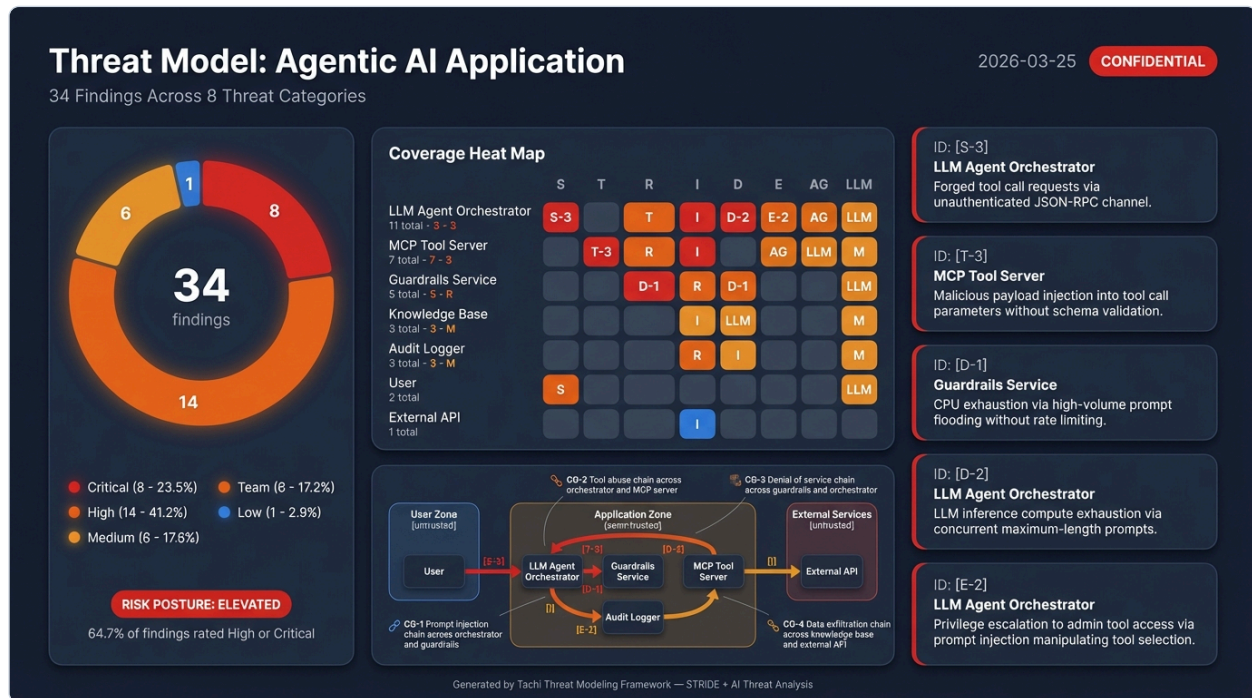
Risk Reduction Funnel



The Risk Reduction Funnel illustrates how the overall risk profile transforms through each stage of the assessment pipeline. The top tier shows all threats identified during the initial STRIDE and AI-specific threat analysis. The second tier reflects severity recalibration after quantitative scoring, where composite scores incorporating CVSS, exploitability, scalability, and reachability may shift initial severity ratings.

The third tier shows the impact of compensating controls detected in the codebase — existing mitigations that reduce effective risk. The bottom tier presents the final residual risk posture, representing the organization's actual exposure after accounting for all identified defenses. The sidebar provides key metrics at a glance, including the total risk reduction percentage, control coverage rate, and the highest-residual-risk finding requiring priority attention.

Risk Summary Dashboard



The Risk Summary Dashboard consolidates assessment results into three complementary views. The left panel displays the residual risk distribution across severity levels, showing how findings are distributed after compensating controls are applied.

The center panel presents a component-by-threat-category heat map, where each cell indicates the highest residual severity for that intersection of system component and STRIDE or AI threat category. This enables rapid identification of which components carry the highest concentration of risk. The right panel highlights the top findings by residual risk score, listing the specific threats that require the most immediate attention with their affected components and residual scores.

Detailed Findings

Findings Detail — Residual Risk

Findings Detail — Residual Risk

HIGH LLM-1

LLM Agent Orchestrator

Adversarial prompts override system prompt

Deploy structured prompt templates with explicit boundary enforcement between system instructions and user input. Use delimiters, role markers, and instruction hierarchy to prevent adversarial prompt override.

Residual: 8.3 | Control: No Control Found

HIGH E-2

LLM Agent Orchestrator

Attacker escalates to admin tool access through prompt injection

Implement role-based access control on tool dispatch. Map user roles to permitted tool sets and enforce at the orchestrator level before dispatching to MCP Tool Server.

Residual: 7.6 | Control: No Control Found

HIGH AG-1

LLM Agent Orchestrator

Orchestrator executes consequential actions without human approval

Establish human-in-the-loop checkpoints for all irreversible or external actions. Classify operations by risk tier and require explicit user approval for consequential actions.

Residual: 7.6 | Control: No Control Found

HIGH E-3

MCP Tool Server

User invokes admin tool endpoints by manipulating tool_name

Enforce per-agent capability scoping on the MCP Tool Server. Each connected client should only access tools permitted by its role and session context.

Residual: 7.5 | Control: No Control Found

HIGH D-2

LLM Agent Orchestrator

Attacker sends concurrent max-length prompts

Add input size caps and concurrent request limits at the orchestrator layer. Implement request queuing with timeout to prevent resource exhaustion from parallel maximum-length prompts.

Residual: 7.3 | Control: No Control Found

HIGH T-3

MCP Tool Server

Attacker manipulates JSON-RPC parameters in transit

Residual: 7.1 | Control: No Control Found

HIGH AG-3

MCP Tool Server

MCP Tool Server exposes all tools without per-agent scoping

Residual: 7.0 | Control: No Control Found

MEDIUM S-1

User

Attacker impersonates legitimate user by replaying tokens

Residual: 5.9 | Control: Partial Control

MEDIUM D-1

Guardrails Service

Attacker floods Guardrails Service to exhaust CPU

Residual: 5.6 | Control: Partial Control

MEDIUM S-3

LLM Agent Orchestrator

Attacker forges tool call requests to MCP Tool Server

Residual: 5.4 | Control: Partial Control

MEDIUM S-2	Guardrails Service
Attacker bypasses Guardrails by directly accessing Orchestrator █ Residual: 5.0 Control: Partial Control	
MEDIUM E-1	Guardrails Service
Attacker bypasses Guardrails via alternate route █ Residual: 5.0 Control: Partial Control	
MEDIUM D-3	MCP Tool Server
Resource exhaustion through concurrent tool calls █ Residual: 4.8 Control: Partial Control	
MEDIUM AG-4	MCP Tool Server
Tool call chaining enables capability escalation █ Implement cross-tool policy evaluation that assesses composite effects of tool call chains. Add a policy engine that evaluates whether a sequence of tool calls exceeds individual permissions. Residual: 6.4 Control: No Control Found	
MEDIUM T-4	Knowledge Base
Attacker injects malicious content into Knowledge Base █ Residual: 4.7 Control: Partial Control	
MEDIUM LLM-2	LLM Agent Orchestrator
Indirect prompt injection via adversarial content in Knowledge Base █ Add content sanitization and anomaly detection on Knowledge Base retrieval results before including them in the LLM context window. Filter or flag content that resembles instruction patterns. Residual: 6.3 Control: No Control Found	

MEDIUM T-2	LLM Agent Orchestrator
Attacker injects malicious content by tampering with data flow	
█	
Residual: 4.6 Control: Partial Control	
MEDIUM D-4	Knowledge Base
Unbounded vector search queries exhaust resources	
█	
Residual: 4.5 Control: Partial Control	
MEDIUM I-3	MCP Tool Server
Raw API error responses forwarded without sanitization	
█	
Residual: 4.2 Control: Partial Control	
MEDIUM D-5	Audit Logger
High-volume logging events cause storage exhaustion	
█	
Residual: 4.0 Control: Partial Control	
MEDIUM AG-2	LLM Agent Orchestrator
Orchestrator operates in unbounded reasoning loop	
█	
Residual: 5.2 Control: No Control Found	
MEDIUM LLM-3	LLM Agent Orchestrator
Systematic querying enables model extraction	
█	
Residual: 5.0 Control: No Control Found	

MEDIUM	R-5	External API
External API interactions lack correlation identifiers		
Residual: 4.6 Control: No Control Found		
MEDIUM	R-4	MCP Tool Server
Tool executions lack requesting orchestrator context		
Residual: 4.3 Control: No Control Found		
LOW	I-1	Guardrails Service
Rejection reasons reveal internal filtering rules		
Residual: 3.1 Control: Control Found		
LOW	I-4	Knowledge Base
Query responses include internal metadata		
Residual: 3.0 Control: Control Found		
LOW	T-1	Guardrails Service
Attacker modifies validation rules at runtime		
Residual: 2.9 Control: Control Found		
LOW	S-4	MCP Tool Server
Attacker redirects outbound API requests via DNS spoofing		
Residual: 2.9 Control: Control Found		

LOW I-2 Verbose error messages leak internal service topology Residual: 2.8 Control: Control Found	LLM Agent Orchestrator
LOW T-5 Attacker modifies audit log entries to cover tracks Residual: 2.7 Control: Control Found	Audit Logger
LOW R-3 Orchestrator executes tool calls without logging decision chain Residual: 3.9 Control: Partial Control	LLM Agent Orchestrator
LOW I-5 Audit logs contain sensitive data accessible beyond security team Residual: 2.6 Control: Control Found	Audit Logger
LOW R-1 User denies having submitted a specific prompt Residual: 2.4 Control: Control Found	User
LOW R-2 Insufficient detail in filtering event logs Residual: 3.4 Control: Partial Control	Guardrails Service

34 findings | Sorted by residual severity (critical first)

Control Coverage

Control Status by STRIDE Category

STRIDE Category	Found	Partial	Missing	Total
Spoofing	1	3	0	4
Tampering	2	2	1	5
Repudiation	1	2	2	5
Information Disclosure	4	1	0	5
Denial of Service	0	4	1	5
Elevation of Privilege	0	1	2	3
Agentic Threats	0	0	4	4
LLM Threats	0	0	3	3

Detailed Control Assessment

Component	Control Category	Status	Evidence	Effectiveness
User	Authentication	Partial	src/middleware/auth.js:15	Moderate
Guardrails Service	Rate Limiting	Partial	src/middleware/rateLimiter.js:8	Moderate
LLM Agent Orchestrator	Encryption	Found	src/config/tls.js:3	Strong
Audit Logger	Logging/Audit	Found	src/services/auditLogger.js:12	Moderate
Guardrails Service	Input Validation	Found	src/services/guardrails.js:25	Moderate

Coverage Summary



Control Status	Count	Percentage
Control Found	8	23.5%
Partial Control	13	38.2%
No Control Found	13	38.2%
Total	34	100%

Remediation Roadmap

■ Critical: 0 ■ High: 7 ■ Medium: 17 ■ Low: 10

34 total actions

Priority	Finding	Recommendation	SLA	Status
HIGH				
7 actions				
LLM-1	Adversarial prompts override system prompt	Deploy structured prompt templates with explicit boundary enforcement between system instructions and user input. Use delimiters, role markers, and instruction hierarchy to prevent adversarial prompt override.	14d	No Control Found
E-2	Attacker escalates to admin tool access through prompt injection	Implement role-based access control on tool dispatch. Map user roles to permitted tool sets and enforce at the orchestrator level before dispatching to MCP Tool Server.	14d	No Control Found
AG-1	Orchestrator executes consequential actions without human approval	Establish human-in-the-loop checkpoints for all irreversible or external actions. Classify operations by risk tier and require explicit user approval for consequential actions.	14d	No Control Found
E-3	User invokes admin tool endpoints by manipulating tool_name	Enforce per-agent capability scoping on the MCP Tool Server. Each connected client should only access tools permitted by its role and session context.	14d	No Control Found
D-2	Attacker sends concurrent max-length prompts	Add input size caps and concurrent request limits at the orchestrator layer. Implement request queuing with timeout to prevent resource exhaustion from parallel maximum-length prompts.	14d	No Control Found
T-3	Attacker manipulates JSON-RPC parameters in transit		14d	No Control Found
AG-3	MCP Tool Server exposes all tools without per-agent scoping		14d	No Control Found
MEDIUM				
17 actions				
S-1	Attacker impersonates legitimate user by replaying tokens		30d	Partial Control
D-1	Attacker floods Guardrails Service to exhaust CPU		30d	Partial Control
S-3	Attacker forges tool call requests to MCP Tool Server		30d	Partial Control

Priority	Finding	Recommendation	SLA	Status
S-2	Attacker bypasses Guardrails by directly accessing Orchestrator		30d	Partial Control
E-1	Attacker bypasses Guardrails via alternate route		30d	Partial Control
D-3	Resource exhaustion through concurrent tool calls		30d	Partial Control
AG-4	Tool call chaining enables capability escalation	Implement cross-tool policy evaluation that assesses composite effects of tool call chains. Add a policy engine that evaluates whether a sequence of tool calls exceeds individual permissions.	30d	No Control Found
T-4	Attacker injects malicious content into Knowledge Base		30d	Partial Control
LLM-2	Indirect prompt injection via adversarial content in Knowledge Base	Add content sanitization and anomaly detection on Knowledge Base retrieval results before including them in the LLM context window. Filter or flag content that resembles instruction patterns.	30d	No Control Found
T-2	Attacker injects malicious content by tampering with data flow		30d	Partial Control
D-4	Unbounded vector search queries exhaust resources		30d	Partial Control
I-3	Raw API error responses forwarded without sanitization		30d	Partial Control
D-5	High-volume logging events cause storage exhaustion		30d	Partial Control
AG-2	Orchestrator operates in unbounded reasoning loop		30d	No Control Found
LLM-3	Systematic querying enables model extraction		30d	No Control Found
R-5	External API interactions lack correlation identifiers		30d	No Control Found
R-4	Tool executions lack requesting orchestrator context		30d	No Control Found
LOW 10 actions				

Priority	Finding	Recommendation	SLA	Status
I-1	Rejection reasons reveal internal filtering rules		90d	Control Found
I-4	Query responses include internal metadata		90d	Control Found
T-1	Attacker modifies validation rules at runtime		90d	Control Found
S-4	Attacker redirects outbound API requests via DNS spoofing		90d	Control Found
I-2	Verbose error messages leak internal service topology		90d	Control Found
T-5	Attacker modifies audit log entries to cover tracks		90d	Control Found
R-3	Orchestrator executes tool calls without logging decision chain		90d	Partial Control
I-5	Audit logs contain sensitive data accessible beyond security team		90d	Control Found
R-1	User denies having submitted a specific prompt		90d	Control Found
R-2	Insufficient detail in filtering event logs		90d	Partial Control